

Incident Report Analysis

DDoS Attack Using ICMP Flood Traffic

Organization	Multimedia company offering web design, graphic design, and social media marketing services
Role	Cybersecurity analyst
Framework Applied	National Institute of Standards and Technology Cybersecurity Framework (NIST CSF)
Incident Type	Distributed denial of service (DDoS) attack caused by an ICMP flood

Executive Summary

The organization experienced a distributed denial of service (DDoS) attack that disrupted internal network services for approximately two hours. The attack consisted of a flood of incoming ICMP packets that overwhelmed network resources and prevented normal traffic from accessing internal network services. Investigation determined that the traffic entered through an unconfigured firewall, which allowed malicious ICMP traffic to reach the internal network without proper rate limiting, filtering, or source validation.

The incident was resolved by blocking incoming ICMP packets, stopping non-critical network services, restoring critical services, and implementing additional security controls. These controls included a firewall rule to rate limit incoming ICMP packets, source IP address verification to reduce spoofed traffic, network monitoring software for abnormal traffic patterns, and an IDS/IPS system to filter suspicious ICMP traffic. The following report applies the five NIST CSF core functions: Identify, Protect, Detect, Respond, and Recover.

Incident Snapshot

Primary cause	Unconfigured firewall allowed a large volume of incoming ICMP traffic to reach the internal network.
Security impact	Internal network services became unavailable to normal users for two hours.
Affected services	Internal network services, critical business services, non-critical services, firewall operations, and network monitoring processes.
Initial containment	Blocked incoming ICMP packets and temporarily stopped non-critical services to reduce load.
Corrective controls added	ICMP rate limiting, source IP address verification, network monitoring, and IDS/IPS filtering.
Business risk	Loss of service availability, reduced productivity, potential customer disruption, and reputational impact.

NIST CSF Incident Report Analysis

Summary

The multimedia company experienced a DDoS attack that disrupted internal network availability for two hours. During the attack, network services stopped responding because the internal network was overwhelmed by a flood of ICMP packets. Normal traffic could not access network resources while the attack was active. The incident management team responded by blocking incoming ICMP packets, taking non-critical services offline, and restoring critical services. After investigation, the cybersecurity team determined that the attack traffic entered through an unconfigured firewall, which allowed spoofed or malicious ICMP traffic to overwhelm network resources. The organization then implemented additional safeguards, including ICMP rate limiting, source IP address verification, network monitoring, and IDS/IPS filtering.

Identify

The attack was identified as a distributed denial of service (DDoS) attack using ICMP flood traffic. The affected systems included the internal network, network services that depended on internal connectivity, firewall traffic filtering, critical and non-critical business services, and monitoring processes responsible for visibility into network traffic. The main security gap was an unconfigured firewall that did not properly limit or validate incoming ICMP packets. The organization should maintain an inventory of internet-facing devices, firewall rules, network services, critical systems, and monitoring tools. Regular audits should verify firewall configurations, permitted protocols, traffic thresholds, and whether controls are aligned with business needs.

Protect

The organization should strengthen preventive controls around network traffic filtering and service availability. Firewall rules should be reviewed and hardened to restrict unnecessary inbound traffic, limit ICMP traffic to approved diagnostic needs, and apply rate limits for traffic that could overwhelm the network. Source IP address verification should remain enabled to reduce spoofed traffic. Critical services should be segmented from non-critical services so that one traffic flood does not affect the entire internal network. Security procedures should define how firewall rules are approved, tested, documented, and reviewed. Employees and IT staff should also receive training on incident escalation procedures and the importance of reporting abnormal service outages quickly.

Detect

The organization should continuously monitor network traffic for abnormal patterns, including sudden spikes in ICMP packets, unusual packet volume from untrusted sources, traffic from spoofed IP addresses, and repeated failed connection attempts. Network monitoring software should generate alerts when traffic exceeds normal baselines. Firewall logs, IDS/IPS alerts, and system availability metrics should be reviewed through a centralized monitoring process, such as a SIEM, to help analysts correlate events and respond faster. Detection rules should be created for ICMP flood behavior, high packet rates, suspicious source distribution, and repeated traffic targeting internal network services.

Respond

For future incidents, the organization should use a documented incident response plan. The first step should be to confirm the event by reviewing firewall logs, IDS/IPS alerts, and service availability reports. The team should then contain the incident by rate limiting or blocking malicious traffic, isolating affected services when needed, and prioritizing restoration of critical business functions. Security staff should preserve relevant logs and packet captures for analysis. Internal communication should clearly identify who is responsible for containment, technical analysis, business communication, and service restoration. After the incident, the team should conduct a post-incident review to document the root cause, response timeline, control gaps, and improvements made.

Recover

The recovery plan should focus on restoring normal network operations, confirming service availability, and improving resilience against similar attacks. Critical services should be brought back online first, followed by non-critical services after the attack traffic has been blocked or reduced. The team should validate firewall rules, IDS/IPS signatures, monitoring alerts, and service performance before declaring the incident fully resolved. Recovery documentation should include the incident timeline, affected systems, changes made, and lessons learned. To improve future recovery, the organization should maintain tested recovery procedures, baseline network performance metrics, backup firewall configurations, and a communication plan for notifying internal stakeholders when service disruptions occur.

Recommended Security Improvements

- Firewall hardening: Document, test, and review firewall rules on a recurring schedule. Restrict inbound ICMP traffic to approved use cases and apply rate limits.

- DDoS resilience: Create thresholds and automated alerts for abnormal packet volume. Consider upstream DDoS protection with the internet service provider or cloud provider if business needs grow.
- Monitoring and logging: Centralize firewall, IDS/IPS, and network monitoring logs so analysts can detect traffic spikes and investigate incidents quickly.
- Segmentation: Separate critical services from non-critical services to reduce the chance that one attack disrupts the entire business environment.
- Response procedures: Maintain an incident response runbook that defines roles, escalation paths, containment actions, communication procedures, and post-incident review steps.

Reflections and Notes

This incident shows how a single weak or incomplete network control can affect availability across an organization. The most important lesson is that preventive, detective, response, and recovery controls must work together. A firewall rule can reduce exposure, monitoring can identify abnormal traffic, IDS/IPS tools can filter suspicious activity, response procedures can reduce downtime, and recovery planning can help restore services quickly. Applying the NIST CSF gives the organization a structured way to turn the incident into long-term security improvements.

Source Materials Used

- Incident report analysis template
- Applying the NIST CSF supporting material
- Completed example of an incident report analysis
- Activity scenario provided in the course instructions